Well-Architected Review for Cloud

- WHAT is a Well Architected Review?
- WHY do we have a WAR?
- WHO needs to complete a WAR?
- How to Initiate a Well-Architected Review
  - Complete Prerequisites
    - 1. WAR Self Assessment Checklist (Optional)
    - 2. Deploy Solution to your Test Account/Subscription
    - 3. (AWS only) AWS Security Hub WAR Scan and Remediation
    - 3. (Azure Only) Cloud Conformity Scan and Remediation
    - 4. Solution Diagram
    - 5. Review Relevant Service Pages
  - Schedule Well Architected Review
- Peer Review Model
- Outputs of WAR Meeting
- WAR Exception Process
- Questions

WHAT is a Well Architected Review?

The Well-Architected Review (WAR) and Well-Architected Framework was developed by AWS "to help cloud architects build secure, high-performing, resilient, and efficient infrastructure for their applications. Based on five pillars — operational excellence, security, reliability, performance efficiency, and cost optimization — the Framework provides a consistent approach for customers and partners to evaluate architectures, and implement designs that will scale over time."

- Download the Framework whitepaper PDF | Kindle

Even though the framework was developed by AWS, it is generalizable to cloud solutions deployed on other Cloud Service Providers like Azure.

WHY do we have a WAR?

The Well Architected Review identifies potential operational problems early and helps make sure cloud use cases are adhering to best practices. Tangible benefits of the WAR have included:

- Incorrect EC2 instance types for the given workload
- Lack of Patching Strategy for EC2 Instances
- Lack of resilient architecture (not using Availability zones appropriately)
- Lack of back-ups and snapshots

The human element of the WAR review adds value that tools like Cloud Conformity cannot. For example, Conformity has a hard time with this type of analysis:

- Why was a serverless option not selected?
- Why did you choose to not use the existing Terrraform pattern for this? Did you even know that was an option?
- Why would you choose this technology for that use case?

WHO needs to complete a WAR?

The WAR process is a formalized step in the Cloud Path to Production (P2P). Partner with your cloud operational readiness partner to determine if you are eligible for scaling (Scaling your Path to Production).

How to Initiate a Well-Architected Review

1

Complete Prerequisites

1. WAR Self Assessment Checklist (Optional)

Additional Detail

Confirm with your operational readiness partner if you're not sure if this is required.

- **AWS:** A blank version of the template is available for reference here: AWS Well Architected Review Checklist
- **Azure:** Complete the Azure WAR Self-Assessment Tool.
- **Openshift/K8s:** Review and complete the informational review and checklist.

If you need help reach out to us on Webex at General - AWS channel , General - Azure channel

2. Deploy Solution to your Test Account/Subscription

What does it mean to be fully deployed to test?

What does it mean to be fully deployed to test?

1. Cloud infrastructure test deployment should functionally match what will be deployed to production
2. Solution needs to be deployed using an automated pipeline
3. All services deployed
4. Solution has been tested and is working
5. Infrastructure as code and all Code Repos deployed and complete (besides minor code changes based on AWS Security Hub or cloud conformity findings)
6. No creating/deleting any resources or introducing any new AWS Security Hub or Azure Cloud Conformity findings

3. (AWS only) AWS Security Hub WAR Scan and Remediation

Run AWS Security Hub scan against the **TEST** account. If there are findings, either mitigate them ahead-of-time, or be prepared to discuss the plan to close the findings.

What defines a Clean AWS Security Hub WAR Report?

1. Zero failed findings after COE Filters Applied:
    a. Pull Security Hub WAR Scan with P2P Automation: On Demand Scans and Documents - User Guide
    b. Validate that resources are tagged appropriately with either SecurityReviewID or P2P
2. Findings Previously exempted from previous iteration
3. Findings have been approved via the WAR Exception process

Note for any use case deployed within a shared Test account which contains other resources not related to the use case under review, ALL must be tagged by SecurityReviewID/P2P
Also a second report of the entire account will be run for the Dev team to cross reference that nothing was missed within the SecurityReviewID/P2P tagged report.

Detailed process to run AWS Security Hub report

1. You can use the Public Cloud On Demand Scans and Documents ServiceNow form found here - https://cigna.service-now.com/esc?id=sc_cat_item&sys_id=2d8b110587cdad1054af33773cbb3541

    - OR -

    View your findings in AWS Security Hub via the Well Architected Review (WAR) Insight.

    a. Follow the Security Hub User Guide step-by-step to learn how to navigate to the Well Architected Review Insight in AWS Security Hub.

3. (Azure Only) Cloud Conformity Scan and Remediation

Run Cloud Conformity against the **TEST** account (the Well Architected Module). If there are findings, either mitigate them ahead-of-time, or be prepared to discuss the plan to close the findings.

What defines a Clean Conformity Report?

1. Zero failed findings after COE Filters Applied:
    a. Run Report through Well Architected Review Framework
    b. Uncheck suppressed and successful
    c. Filter out all security pillar and/or low risk level findings
2. Findings Previously exempted from previous iteration
3. Findings have been approved via the WAR Exception process

Note for any use case deployed within a shared Test account which contains other resources not related to the use case under review, ALL must be tagged by SecurityReviewId .
Also a second report of the entire account will be run for the Dev team to cross reference that nothing was missed within the CSCA tagged report.

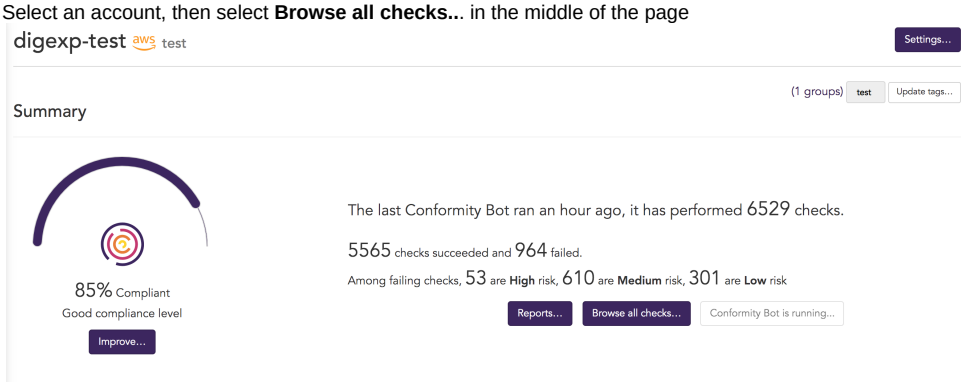
Detailed process to run Cloud Conformity

1. You can use the Public Cloud On Demand Scans and Documents ServiceNow form found here - https://cigna.service-now.com/esc?id=sc_cat_item&sys_id=2d8b110587cdad1054af33773cbb3541

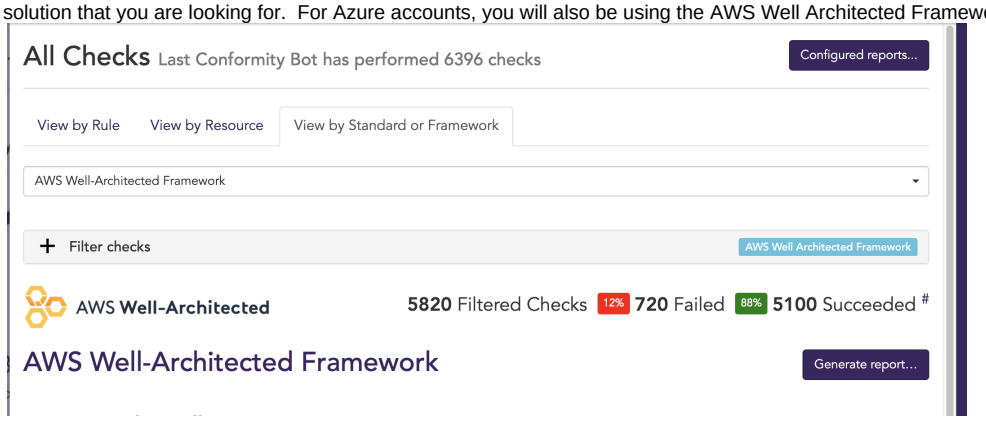
   - OR -

   Run your own report using Cloud Conformity

1. Login via Okta - https://cigna.okta.com
   a. Add Cloud Conformity to your Okta Apps (if you haven't already done so)
   b. If you don't have access please make sure you have the proper global groups
2. Use **Search** to select the right AWS account or Azure account
   a.

3. For Users with the **G_CC_READONLY** role access:
   a. Select an account, then select **Browse all checks..** in the middle of the page
   b. 

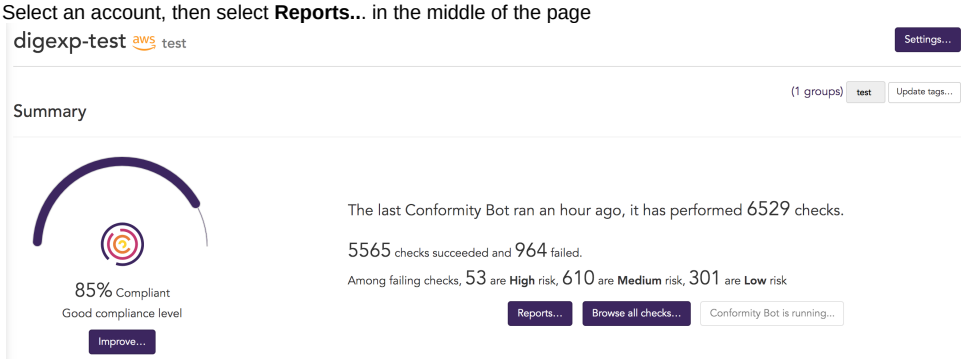
c. Select the View by Standard or Framework and see that the Well Architected Framework is there. If the account that you are generating the report for includes multiple solutions use the **+ Filter checks** to filter by a specific **Tag** for the solution that you are looking for. For Azure accounts, you will also be using the AWS Well Architected Framework.



i. Click **Generate Report...**

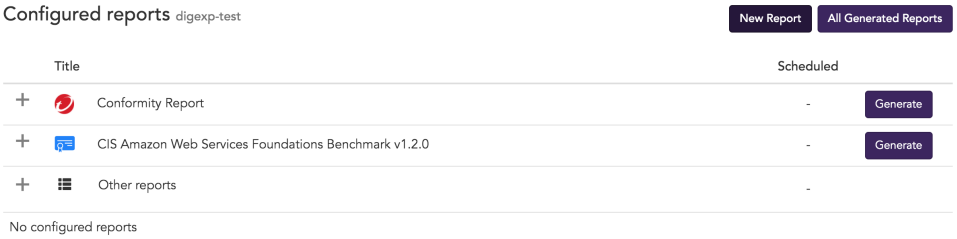
4. For Users with the **G_CC_POWERUSER** role access:

a. Select an account, then select **Reports...** in the middle of the page



b.

c. Select **New Report** in upper right-hand corner

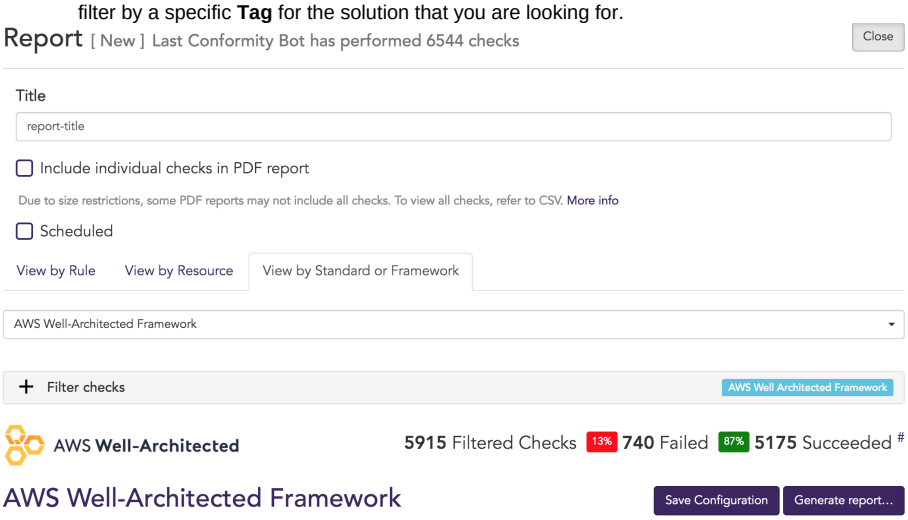


d.

e. Give the Report a Title and select **View by Standard or Framework** and see that the Well Architected Framework is there (use this option for both AWS and Azure based accounts).

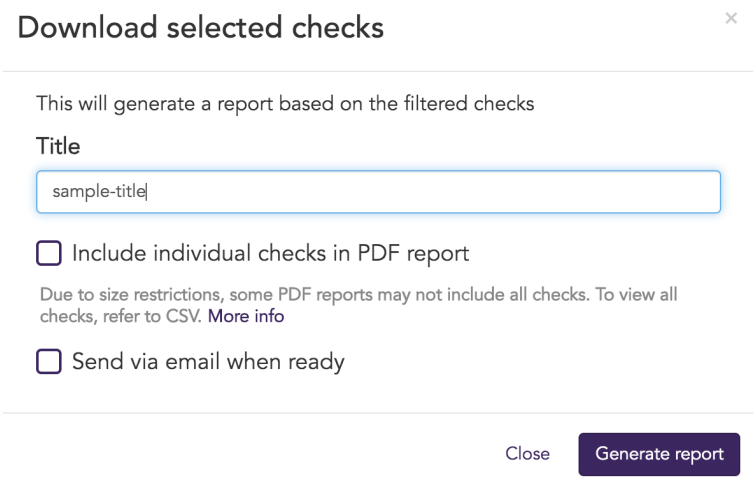
f. Click **Generate Report...**

i. If the account that you are generating the report for includes multiple solutions use the **+ Filter checks** to filter by a specific **Tag** for the solution that you are looking for.



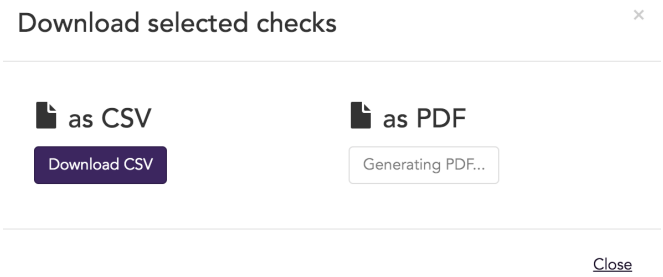
g.

5. Give the report a title



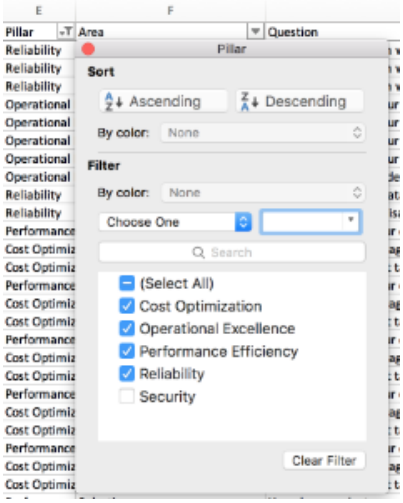
a.

6. Download the **CSV**



a.

7. Open the CSV in your favorite spreadsheet software, I will use Excel in the example
   a. Add Filters with the spreadsheet
      i. **Exclude the Security Pillar** (CIP covers this via the ASAQ)



      ii.
      iii. **Exclude Lows** using similar Filters
   b. Add Columns to add any Suppressions or Comments you need to add as you review

B	C	D
Suppression	Comments	Team Comments
N	Discuss	Shared account, not relevant for project under review
N	Discuss	Shared account, not relevant for project under review
N	Discuss	EBS volume w/ 1 AZ; limitation of Looker itself (not in scope for this project)
N	Low?	Fixed
N	Low?	Fixed
N	Object Level Logging Enabled?	Fixed
N	Object Level Logging Enabled?	Fixed
N	Discuss	Intential Operational decision because of temporal (ephemeral) nature of TF
N	Discuss	Intential Operational decision because of temporal (ephemeral) nature of TF
N	Discuss	Intential Operational decision because of temporal (ephemeral) nature of TF
N	Digital expenses, awareness, not a blocker	
N	Digital expenses, awareness, not a blocker	

      i.
   c. Go through the findings and add any comments you need to and any suppression suggestions that you'd like to give to the Cloud COE

If you don't have access to Cloud Conformity then contact the Cloud COE (CloudCOE@cigna.com) and either we will provision you access (if licensed) or we can generate the output on your behalf.

4. Solution Diagram

Produce a detailed **diagram of the solution** under review, ideally the one produced for the security review (CSCA)

- Guidance on the details required in the Architecture diagram can be found here: Cloud Design Diagram Basics

5. Review Relevant Service Pages

Service pages (AWS / Azure) have been created to help you learn best practices for any services you are using. Review these pages for information on operations, security, tagging, etc. and develop your solution in alignment with the guidelines.

2

Schedule Well Architected Review

Book a timeslot via the Cloud COE Office Hours page, including all relevant documentation

Peer Review Model

As Cigna continues to scale its cloud practice, we need to expand the roster of folks that can help review and assess the architecture pillars. The Peer Review team is comprised of Cigna cloud architects and engineers both within the Cloud COE and outside of the COE that have experience developing cloud solutions.

- The peer review team should familiarize themselves with the WAR materials before the review date so that the review process is concise and focuses on the right topics.
- Each use case WAR request will be assigned two lead peer reviewer's that will be responsible for reviewing the required WAR documents and presenting during the review meeting.
- Peer Review team meets to conduct WAR's during Cloud COE Office Hours

At least 3 reviewers need to attend each session, which means that not every reviewer needs to attend each week but we do have to have enough to form a quorum.

Meet the Team - AWS WAR

AWS Peer Reviewers

- Nocerino, Nick
- Steinman, Gavilan HHHH
- Sutter, Noah HHHH
- Hollant, Hunter 3W4A
- Olson, Jonathan D (Jon) 693
- Lafferty, Ryan HHHH
- Browning, Robert 610
- Paolangeli, Joseph G (Joe) W221A
- Cully, Gregory HHHH
- Pryor-Bennett, Nick A3PMO
- Robichaud, Michael J HHHH
- Choi, Matt HHHH
- Armenta, Sergio HHHH
- Williams, Sarah HHHH
- Silberquit, Ross 693
- De Young, Nick A
- Swanson, Luke
- Sansom, Kory R
- Nuytten, Luc

AWS TAM / SA Reviewers

- Jonathan Banas
- Saravanan Krishnaraj

Meet the Team - Azure WAR

Azure Peer Reviewers

- Whalen, Jason M TL13C
- Coudriet, David HHHH
- Cully, Gregory HHHH
- Zalinski, Grzegorz G (Greg) LLCIP
- Schroeder, Michael HHHH
- Demmon, Quentin D HHHH
- Huey, Scott HHHH
- Bhat, Narayan TN7
- Farah, Nermeen
- Bayldon, Jason
- McNeill, Peter

Azure TAM / SA Reviewers

- Ted Kim
- Abbott Lowell

Meet the Team - Exception Only WAR

Exception Only Peer Reviewers

- Cully, Gregory HHHH
- Coudriet, David HHHH
- Zalinski, Grzegorz G (Greg) LLCIP
- Gagnon, Seth R HHHH
- Nocerino, Nick
- Lin, Yanshen

Actions Required of Peer Reviewers

Review the overall architecture

1. All relevant architecture artifacts should be listed in the Cloud COE Office Hours page, where the WAR review item is listed
    a. If you don't see the artifacts contact O'Brien, Blake A8MMand he will follow-up with the Delivery team
2. Note any potential problem areas for discussion during the formal WAR review

Review Team's (Optional) WAR Self-Assessment Checklist

1. For AWS only - Review the solution team's AWS Well Architected Review checklist page (attached to the office hours sign up page). Please note that this checklist is optional and may note exist.
2. Note any potential problem areas for discussion during the formal WAR review

Pull a CSV extract of the latest Security Hub (AWS) or Cloud Conformity (Azure) Report for the target account (usually the test account)

1. Review all **High** and **Medium** Findings (filter out Lows)
2. Note any spurious or questionable findings - the Cloud COE will continue to modify the out-of-the-box rules or add suppressions as needed
   Add any notes for items that required deeper discussion during the formal WAR review
    a. Here's an **example spreadsheet** from a recent review

Conduct the WAR with the delivery team and note responses to any findings

If there are **any unclosed High or Medium findings** that can't be addressed via the WAR discussion, write-up a WAR Exception and list any relevant contextual detail that would be helpful for a sign-off
    a. Example of WAR Exception
    b. Another Example
2. Delivery team is responsible for any sign-offs on unclosed findings. These findings will also be socialized with Cloud CoE and solution team leadership during the approvals process.

Outputs of WAR Meeting

1. **Vote “Approved” by Peer Reviewers during scheduled WAR meeting**
    a. Minimum 3 votes for approval required (any vote for "not-approved" will require the use case go through the exception process)

    b. COE Peer Reviewers can make suggestions which will be listed within takeaway notes
2. **Formal Exception**
    a. Any findings during the review should be captured in the WAR Exception Page and also listed on the Path-to-production page for the relevant solution. It's recommended that teams also manage their findings through their own team backlogs, be that in Rally or GitLab, or other.
    b. *All findings on the WAR exception page should be closed before production. If a team decides not to resolve a finding, a formal exception (with approvals) is required.* Please refer to below process.

Suggestion vs Finding?

Suggestion: Noted as a takeaway by the Peer Reviewer, but if not completed would not stop the use case from going to Production

Finding: Needs to be tracked on a WAR Exception Page and either remediated or signed-off on by identified parties.

WAR Exception Process

Once a formal Well Architected Review has been completed and if there is a need for a WAR Exception use the **Well Architected Review - Exception Template** to document the exceptions and proper sign offs. The WAR template describes how to document each finding, how to determine the correct risk level, and how to determine the proper sign offs needed. Below is a summary of the process but you can find more detailed instructions on the **Well Architected Review Exception Steps Page!**

Initiation

Peer-Reviewers will not vote 'Approved' and will require solution team to go through formal exception process.

The **Leader Peer Reviewers** will draft a list of Findings using the **Well Architected Review - Exception Template** comprised of both Architectural Findings as well as any Tool-generated findings (e.g., Cloud Conformity Report)

1. The **Lead Reviewers** are free to invite other peer reviewers to add items or comment of existing findings at their discretion

---

Solution Team Risk Remediation/Response

The **Solution Team** responds to each identified finding under the "*Solution Team Respond" Column* and explains that they will accept the risk OR prove (attachment, screenshot, etc.) to the peer reviewers that the risk has been remediated completely. After all the comments are added please notify the **Lead Peer Reviewers.**

1. The **Solution Team** can challenge the risk severity of the finding if they believe there are contextual factors warrant downgrading the finding. For example, with a Resiliency finding the Solution Team may state their SLO/SLA is "relaxed" (e.g., say <97%) and, as such, would not require a high availability architecture.

The **Lead Peer Reviewers** will then review the responses and if they agree there is no longer a risk they will strikethrough that finding. Any remaining findings will need email approvals and the **Lead Peer Reviewers** will notify the Solution team when the list is finalized and ready for that stage. Any non-valid findings (Peer reviewer misunderstanding) can be removed, but valid findings with responses need to remain even if remediated (but use ~~strikethrough~~ to show it's no longer an issue)

Exception Approvals

If **ALL findings** are remediated to the satisfaction of the **Lead Reviewer**, the WAR Exception is closed, without additional Exception approvals required. The **Cloud COE** will then ask for email approval from the **Lead Peer Reviewers** that all findings have been remediated and the WAR is now approved. **The Cloud COE** will attach these emails to the WAR Exception page.

OR

1. **Any non-remediated security findings should be tracked in OnSpring as a FND.**
    a. The CSCA security advisor can create these findings for you and will manage sign offs.
    b. Once an Archer FND is created, the security finding can be striked from the WAR exception page.
    c. If there are no other exceptions, the WAR exception can be closed via approval from the 2 WAR peer reviewers. If there are further exceptions, proceed to step 2.
2. If there are any open or accepted or non-remediated findings:
    a. The **Solution Team** we will then need to collect email approvals (from both your delivery team and the business side) and attach them to the WAR Exception page, stating they have reviewed the risks and accept them. As the page explains, the identified risk level will decide which band level is needed for sign-off.
        i. If business sign off is not applicable, please provide email justification and attach this to the exception page.

b. Once the **Solution Team** has attached both email approvals to the WAR Exception page they will notify the **Cloud COE** who will assist in obtaining the Cloud COE and Pillar email approvals. The Cloud CoE will also socialize these findings with solution team leadership for transparency as needed.

COE Sign-Off (Nocerino, Nick)

Architectural Pillar Sign-Off:

1. Operational Excellence (DeFreitas, Sandra L (Leigh) HHHH)
2. Reliability (DeFreitas, Sandra L (Leigh) HHHH)
3. Security (No pillar sign off required; this should be tracked and approved via CIP in Archer)
4. Performance Efficiency (Steinman, Gavilan HHHH)
5. Cost Optimization (Gauer, Nicole B C4PRD)

Roles and Responsibilities Overview

Lead Peer Reviewer Responsibilities

Draft Finding Wiki page

Rate Findings

Review Solution Team responses and, if response/actions are satisfactory, ~~strikethrough~~ findings

Upgrade/downgrade risk based on contextual factors stated in the solution team response

Solution Team Responsibilities

Respond to each Finding by fixing issue or stating that the risk will be accepted

Provide evidence of closure (e.g., screenshots, logs)

Gather exception approvals on the Delivery Team side

Provide overall project management; the speed of closure and Exception approval will largely be dictated by how quickly the Findings get a response and evidence is collected. The Lead Peer Reviewers aren't project managers and therefore the Solution Team will need to provide the overall PM tracking to ensure timely completion to meet delivery commitments.

Solution Team SLA to complete is 8- weeks or another WAR may be required (extensions determined on a case-by-case basis).

Questions

For other questions about the Well-Architected Framework please:

Reach out to us on WebEx at the General- AWS WebEx channel: https://eurl.io/#Dmab3qUHS

Reach out to us on WebEx at the General - Azure WebEx channel : https://eurl.io/#JpQztPHsv

Leave a comment/question on this wiki page

Email CloudCOE@cigna.com